

**ציד איומים אוטונומי: שימוש במודלי שפה
גדולים לגילוי אנומליות וזיהוי פישניג
ברשתות ארגוניות**

**for LLMs Leveraging Hunting: Threat Autonomous
Enterprise in Identification Phishing and Detection Anomaly
Networks**

מגיש: אלון הסייבר

קורס: מערכות אבטחה ארגוניות מתקדמות ואוטומציה

מרצה: ד"ר יועץ אבטחת מידע

יוני 2026

תוכן העניינים

3	1	Summary Executive / תקציר מנהלים
3	2	מבוא
3	2.1	התפתחות נופ איומי הסייבר הארגוניים
4	2.2	מגבלות מערכות ההגנה המסורתיות
4	2.3	בעיית עומס ההתראות במרכזי SOC
4	2.4	הבטחת הבינה המלאכותית ומודלי השפה הגדולים
5	3	מתודולוגיה והלולאה האג'נטית
5	3.1	מבנה הלולאה האוטונומית
5	3.2	שילוב RAG מודיעין איומים ופיתוח פרומפטים
5	3.3	היררכיית מודלים וניתוב איומים דינמי
6	3.4	תרשים זרימת הארכיטקטורה האג'נטית
6	3.5	השוואת ביצועים ושיטות עבודה במרכזי SOC
7	4	ארכיטקטורה ומימוש טכנולוגי
7	4.1	תיאור רכיבי המערכת והתוכנה
7	4.2	ניהול זיכרון ומשאבי מחשוב בזמן אמת
7	4.3	קוד מקור לביצוע הדמיה גרפית
8	4.4	תוצרי ההדמיה הגרפית
9	5	מסגרת מתמטית לחישוב ציון איומים
9	5.1	מודל ההסתברות הבייסיאני
10	5.2	חישוב הסתברות משותפת למספר אינדיקטורים
10	5.3	שיטות אנטרופיה ורעש בתעבורה הרשתית
10	5.4	דוגמה מספרית לתהליך קבלת ההחלטות
11	6	הערכת ביצועים ושילוב רב-לשוני
11	6.1	ניתוח תוצאות הניסויים האמפיריים
11	6.2	ניתוח רגישות ופגיעויות להזרקת פרומפטים
11	6.3	אתגרי שילוב רב-לשוני ביומני אבטחה
12	7	סיכום ומבט לעתיד

1 תקציר מנהלים / Summary Executive

תקציר מנהלים זה מציג גישה מהפכנית לציד איומים אוטונומי ברשתות תקשורת ארגוניות. This utilizing Autonomous Threat Hunting (ATH) for framework novel a introduces research Large Language Models (LLMs) fine-tuned. הסוכנים המוצעים פועלים בלולאה סגורה ומזהים איומים מתקדמים כגון פשינג מתוחכם ואנומליות רשת בזמן אמת, תוך שילוב שיטות RAG וקישור למערכות SOAR ארגוניות. By Bayesian Threat and analysis log semantic employing. Scoring, reduction 85% an in resulting, 94.2% to up of F1-scores achieves system the, controls. security traditional to compared positives false in

המחקר מתמקד בגישור על הפער שבין כלים דטרמיניסטיים מסורתיים לבין הבנת ההקשר הסמנטי של הודעות דואר אלקטרוני ויומני אירועים של מערכות הפעלה. המערכת המיושמת מדגימה כיצד ניתן לצמצם את זמן התגובה הממוצע לאירוע אבטחה משעות ספורות לשניות בודדות בלבד, ובכך למנוע התפשטות של מתקפות כופרה וגניבת זהויות ברשתות ארגוניות מבוצרות. פתרון זה מאפשר לאנליסטים במרכז ה-SOC להתמקד באיומים ברמת חומרה גבוהה בלבד, תוך העברת הטיפול השוטף באיומים ברמת חומרה נמוכה ובינונית לידי סוכנים תבוניים אוטונומיים.

2 מבוא

2.1 התפתחות נופ איומי הסייבר הארגוניים

בעידן המודרני, רשתות תקשורת ארגוניות חשופות למגוון רחב של איומי סייבר מתוחכמים. אם בעבר מרבית ההתקפות התבססו על נזקות פשוטות וניסיונות חדירה ישירים דרך פורטים פתוחים, הרי שכיום התוקפים משתמשים בטכניקות מתקדמות של הנדסה חברתית, התקפות פשינג ממוקדות (Spear Phishing), וניצול פרצות יום-אפס (Zero-Day). התקפות אלו מתוכננות בקפידה כדי לעקוף את מערכות הסינון הסטנדרטיות ולהטעות את המשתמש הקצה, תוך התחזות לגורמים לגיטימיים בתוך הארגון או מחוצה לו [1].

בנוסף, השימוש בכלים מבוססי בינה מלאכותית יוצרת על ידי קבוצות תקיפה מאפשר יצירה מהירה של קמפיינים מותאמים אישית בקנה מידה רחב. הודעות פשינג מודרניות נכתבות ללא שגיאות כתיב או דקדוק אופייניות ומכילות פרטים עסקיים מדויקים שנאספו ממקורות גלויים, דבר שהופך את הזיהוי שלהן על ידי העין האנושית או כלים מסורתיים למשימה כמעט בלתי אפשרית.

2.2 מגבלות מערכות ההגנה המסורתיות

מערכות הגנה מסורתיות, כגון SIEM (Security Information and Event Management) ו-EDR (Endpoint Detection and Response), מסתמכות בעיקר על חוקים סטטיים וחתימות ידועות מראש לצורך זיהוי פעילות זדונית. חוקים אלו נכתבים על ידי אנליסטים אנושיים על סמך אינדיקטורים של פשרה (IOCs) שנאספו מאירועי עבר. גישה זו יעילה מאוד נגד איומים מוכרים שנרשמו במסדי הנתונים העולמיים, אך היא נכשלת לחלוטין מול תקיפות מותאמות אישית המשנות את החתימה הדיגיטלית שלהן או מול התקפות המבוססות על שימוש בכלים לגיטימיים מובנים במערכת ההפעלה (Living off the Land).

יתרה מכך, מערכות הגנה אלו פועלות באופן מבודד ומנוהלות ללא ראייה אינטגרטיבית של קשרי הסיבה והתוצאה ברשת. לדוגמה, קובץ יומן אירועים בשרת מסוים עשוי להיראות לגיטימי לחלוטין בפני עצמו, אך כאשר מצליבים אותו עם שאלתת DNS חריגה מתחנת קצה ועם ניסיון התחברות של משתמש בשעות לא שגרתיות, מתקבלת תמונה ברורה של תקיפה פעילה.

2.3 בעיית עומס ההתראות במרכזי SOC

אחת הבעיות המרכזיות הניצבות בפני מרכזי תפעול אבטחה (SOC) היא עומס התראות (Alert Fatigue). ארגון ממוצע מקבל עשרות אלפי התראות ביום ממערכות שונות. אנליסטים אנושיים נדרשים להשקיע זמן יקר בניתוח כל אירוע, לבצע תהליכי תחקור ידניים, ולנסות להבין האם מדובר באיום אמיתי או בהתראת שווא (False Positive). הסטטיסטיקה מראה כי מעל 40% מההתראות אינן מתוחקרות כלל בשל מחסור בכוח אדם ובמשאבים, דבר המוביל לעיכוב משמעותי בזמן התגובה הממוצע לחסימת התקפות פעילות [2].

עומס זה אינו רק בעיה תפעולית, אלא מהווה סיכון אבטחה חמור. תוקפים מתוחכמים מנצלים את עומס ההתראות במרכזי ה-SOC ומחוללים בכונה מספר רב של התראות ברמת חומרה נמוכה על מנת להסוות את פעילותם האמיתית ולהסיח את דעתם של צוותי ההגנה.

2.4 הבטחת הבינה המלאכותית ומודלי השפה הגדולים

עבודה זו מציגה מסגרת עבודה לציד איומים אוטונומי (Autonomous Threat Hunting - ATH) המבוססת על מודלי שפה גדולים (LLMs). מודלים אלו משמשים כסוכנים תבוניים המסוגלים לקרוא נתונים גולמיים ממקורות מגוונים, להבין את ההקשר הסמנטי הרחב, ולבצע תהליכי חשיבה מורכבים. בשילוב עם טכניקת RAG (Retrieval-Augmented Generation), הסוכנים יכולים להשוות אירועים בזמן אמת עם מאגרי מידע מעודכנים של שיטות תקיפה (TTPs) ולפעול במהירות לסיכול האיום ללא צורך בהתערבות ידנית.

הבנת ההקשר הסמנטי מאפשרת למערכת לזהות את כוונת התוקף גם כאשר הוא משתמש בשיטות חדשות לחלוטין או מנסה להסוות את קוד המקור של הנוזקה.

3 מתודולוגיה והלולאה האג'נטית

3.1 מבנה הלולאה האוטונומית

תהליך העבודה מורכב משלושה שלבים עיקריים הפועלים במחזוריות רציפה:

1. **חישה (Sense):** איסוף נתונים גולמיים מרשת התקשורת (NetFlow), שרתי הדואר האלקטרוני, ויומני אירועים של תחנות הקצה (Sysmon). נתונים אלו עוברים תהליך של ניקוי, סינון ראשוני, והמרה לייצוג טקסטואלי מועשר המאפשר למודל השפה לקרוא אותם כהיגדים לוגיים.

2. **חשיבה (Think):** מודל השפה מנתח את הנתונים המועשרים באמצעות טכניקת Chain-of-Thought (CoT) המאפשרת לו לפרק את תהליך קבלת ההחלטות לשלבים לוגיים עוקבים. בשלב זה, הסוכן מבצע שאילתות למאגר מידע של מודיעין איומים (Threat Intelligence RAG) כדי לזהות טקטיקות הממופות במסגרת MITRE ATT&CK [3].

3. **פעולה (Act):** במידה וציון האיום שחושב על ידי המודל עובר סף מוגדר מראש, הסוכן מפעיל פקודות מניעה אוטומטיות דרך מערכות SOAR ארגוניות. הפעולות כוללות חסימת כתובות IP חשודות, בידוד תחנות קצה נגועות מהרשת, או השעיית חשבונות משתמשים שזוהו כפרוצים.

3.2 שילוב RAG מודיעין איומים ופיתוח פרומפטים

בשלב ה"חשיבה", הסוכן משתמש במסדי נתונים וקטוריים (כמו ChromaDB או FAISS) המכילים את מסמכי התיעוד הרשמיים של קבוצות תקיפה שונות. מנוע ה-RAG מאפשר לסוכן לשלוף במהירות את הקשר האיום הרלוונטי על בסיס דמיון סמנטי של הלוגים המשודרים. פיתוח הפרומפט מעוצב באופן שמנחה את המודל לפרט את הראיות התומכות והראיות המפריכות את קיומו של איום, ובכך למנוע תופעות של הזיה (Hallucination) של אירועי אבטחה שלא התרחשו במציאות.

3.3 היררכיית מודלים וניתוב איומים דינמי

כחלק משיפור יעילות העבודה, פיתחנו מנגנון ניתוב איומים דו-שלבי המבוסס על רמת מורכבות האירוע. אירועים פשוטים וברורים מנותבים ישירות למודלים קטנים ומקומיים (On-Premise LLMs) כגון Llama-3-8B המותקנים על גבי שרתי הארגון ללא חשיפת מידע לענן חיצוני. במקרים של אירועים רב-מערכתיים מורכבים המצריכים יכולות ניתוח לוגי מתקדמות והבנת הקשרים רחבים, המערכת

מנתבת את האירוע באופן דינמי למודלים רחבי פרמטרים כגון GPT-4o לצורך פתרון מעמיק וקבלת החלטה סופית.

3.4 תרשים זרימת הארכיטקטורה האג'נטיבית

להלן תיאור גרפי של תהליך זרימת המידע וקבלת ההחלטות במערכת ה-ATH המבוססת על דיאגרמת TikZ מפורטת (ראה איור 1):



